

Antum People · Compliance Pack

Data Protection Impact Assessment Questionnaire (UAE & KSA)

Version 1.1 · 2026-09-17 · Pilot-ready · EN / AR

Data Protection Impact Assessment (DPIA) Questionnaire

استبيان تقييم أثر حماية البيانات (DPIA)

Jurisdictions / النطاق القانوني: UAE (Federal Decree-Law No. 45 of 2021) and KSA (Royal Decree M/148, as amended 2023)

Status / الحالة: Template v1.0 — pilot-ready

Version / الإصدار: v1.1 (2026-09-17) — brand aligned to Antum People

Usage / الاستخدام: Complete before deploying high-risk HR processing (e.g., predictive analytics, biometric data, cross-border transfer). Map responses to `dpa\_assessments` + `dpa\_responses` tables.

ENGLISH VERSION

Instructions

Complete every section. Rate each risk as **Likelihood (1-5) × Impact (1-5)**. A DPIA is **mandatory** for: (1) any analytics/Intelligence-Tier deployment, (2) biometric or health data processing, and (3) cross-border transfer of employee data.

A. Screening & Processing Overview

#	Question	Response
A1	Project / processing activity name	[project_name]
A2	Purpose of processing	[purpose]
A3	Lawful basis (consent / contract necessity / legal obligation / legitimate interest)	[lawful_basis]
A4	Data subject categories (employees, applicants, dependants, ex-employees)	[data_subject_categories]
A5	Personal data categories collected	[data_categories]
A6	Is sensitive data involved (health, biometric, ethnicity, religion)?	☐ Yes ☐ No
A7	Controller / Processor	[controller_ref] / [processor_ref]
A8	Retention period & deletion schedule	[retention_schedule]
A9	Is there a cross-border transfer ? Destination & mechanism	☐ No ☐ Yes: [destination] via [mechanism]

B. Necessity & Proportionality

#	Question	Yes / No	Notes
B1	Is the processing necessary to achieve the purpose (no less-intrusive alternative)?	☐ / ☐	
B2	Is data minimised (only what is required)?	☐ / ☐	
B3	Are data subjects informed via a privacy notice at collection?	☐ / ☐	
B4	Is a lawful basis recorded for every purpose?	☐ / ☐	
B5	Automated-processing disclosure (UAE PDPL Art. 14): are employees informed when AI / automated systems (e.g., AI agents) process their data or make decisions about them, and is human oversight available?	☐ / ☐	
B6	Does any automated decision produce a legal or similarly significant effect on employees?	☐ / ☐	

C. Risk Identification & Scoring

Score each risk **Likelihood (1-5) × Impact (1-5) → Score (1-25)**.

#	Risk category	Likelihood	Impact	Score
C1	Unauthorised access to personal data	__ /5	__ /5	__
C2	Data loss, corruption, or alteration	__ /5	__ /5	__
C3	Excessive retention (data kept beyond purpose)	__ /5	__ /5	__
C4	Function creep / re-purposing	__ /5	__ /5	__
C5	Cross-border exposure (inadequate destination protection)	__ /5	__ /5	__
C6	Automated bias / unfair profiling	__ /5	__ /5	__
C7	Third-party / vendor compromise	__ /5	__ /5	__
C8	DSR non-fulfilment (access/erasure delays)	__ /5	__ /5	__

D. Risk Assessment Summary

Total score (sum of C1-C8)	Band	Required action
8-32	Low	Accept; document rationale
33-64	Medium	Mitigate; re-assess in 12 months
65-152	High	Mitigate before go-live; re-assess in 6 months
153-200	Critical	Do not proceed until residual ≤ Medium; escalate to DPO

Regulator consultation trigger: if residual risk remains **High/Critical** after mitigation, consult the supervisory authority — **UAE Data Office** (UAE) or **SDAIA/NDMO** (KSA) — before processing.

E. Mitigation Measures

#	Control	Addressed?	Residual Likelihood	Residual Impact
E1	Encryption (AES-256 at rest, TLS 1.2+ in transit)	☐	__ /5	__ /5

#	Control	Addressed?	Residual Likelihood	Residual Impact
E2	Role-based access control (RBAC)	☐	__ /5	__ /5
E3	Retention auto-purge / anonymisation	☐	__ /5	__ /5
E4	Purpose tagging + lawful-basis enforcement	☐	__ /5	__ /5
E5	Geo-partitioning + SCCs / adequacy for transfers	☐	__ /5	__ /5
E6	Human-in-the-loop for automated decisions	☐	__ /5	__ /5
E7	Vendor DPA + security questionnaire + breach clause	☐	__ /5	__ /5
E8	DSR workflow with 30-day SLA + erasure engine	☐	__ /5	__ /5

F. Residual Risk & Sign-off

Field	Value
Residual risk score (after mitigation)	[residual_risk_score]
Residual risk band	☐ Low ☐ Medium ☐ High ☐ Critical
DPO review	[dpo_reviewer] — [dpo_review_date]
Controller sign-off	[controller_sign_off] — [sign_off_date]
Review due date	[review_due_date]

التعليمات

أكمل كل قسم. قِيم كل خطر ك الاحتمالية (5-1) × الأثر (5-1). يكون تقييم الأثر إلزامياً في الحالات التالية: (1) أي نشر لتحليلات/طبقة الذكاء، (2) معالجة البيانات البيومترية أو الصحية، و(3) نقل بيانات الموظفين عبر الحدود.

أ. الفحص ونظرة عامة على المعالجة

#	السؤال	الإجابة
A1	اسم المشروع / نشاط المعالجة	[project_name]
A2	الغرض من المعالجة	[purpose]
A3	الأساس القانوني (موافقة / ضرورة تعاقدية / التزام قانوني / مصلحة مشروعة)	[lawful_basis]
A4	فئات أصحاب البيانات (موظفون، متقدمون، مُعالون، موظفون سابقون)	[data_subject_categories]
A5	فئات البيانات الشخصية المجمعة	[data_categories]
A6	هل توجد بيانات حساسة (صحية، بيومترية، عرقية، دينية)؟	☐ نعم ☐ لا
A7	جهة التحكم / المعالج	[processor_ref] / [controller_ref]
A8	فترة الاحتفاظ وجدول الحذف	[retention_schedule]
A9	هل يوجد نقل عبر الحدود؟ الوجهة والآلية	☐ نعم: [destination] عبر ☐ لا ☐ [mechanism]

ب. الضرورة والتناسب

#	السؤال	نعم / لا	ملاحظات
B1	هل المعالجة ضرورية لتحقيق الغرض (لا يوجد بديل أقل تدخلاً)؟	☐ / ☐	
B2	هل البيانات مُقلصة (فقط ما هو مطلوب)؟	☐ / ☐	
B3	هل تم إعلام أصحاب البيانات عبر إشعار خصوصية عند الجمع؟	☐ / ☐	
B4	هل تم تسجيل أساس قانوني لكل غرض؟	☐ / ☐	
B5	الإفصاح عن المعالجة الآلية (قانون الإمارات المادة 14): هل يتم إعلام الموظفين عند معالجة بياناتهم بواسطة أنظمة الذكاء الاصطناعي/الأنظمة الآلية (مثل وكلاء الذكاء الاصطناعي) أو عند اتخاذ قرارات بشأنهم، وهل تتوفر رقابة بشرية؟	☐ / ☐	
B6	هل ينتج عن أي قرار آلي أثر قانوني أو مماثل في الأهمية على الموظفين؟	☐ / ☐	

ج. تحديد المخاطر وتقييمها

قِيم كل خطر: الاحتمالية (5-1) × الأثر (5-1) → النتيجة (25-1).

#	فئة الخطر	الاحتمالية	الأثر	النتيجة
C1	الوصول غير المصرح به إلى البيانات الشخصية	5/ __	5/ __	__
C2	فقدان البيانات أو تلفها أو تعديلها	5/ __	5/ __	__
C3	الاحتفاظ المفرط (بيانات تتجاوز الغرض)	5/ __	5/ __	__
C4	انحراف الغرض / إعادة الاستخدام	5/ __	5/ __	__
C5	التعرض عبر الحدود (حماية غير كافية في الوجهة)	5/ __	5/ __	__
C6	التحيز الآلي / التمييز غير العادل	5/ __	5/ __	__
C7	اختراق طرف ثالث / موّرد	5/ __	5/ __	__
C8	عدم تلبية طلبات أصحاب البيانات (تأخير الاطلاع/المحو)	5/ __	5/ __	__

د. ملخص تقييم المخاطر

إجمالي النتيجة (مجموع C1-C8)	النطاق	الإجراء المطلوب
32-8	منخفض	قبول؛ توثيق المبرر
64-33	متوسط	معالجة؛ إعادة تقييم خلال 12 شهراً
152-65	مرتفع	معالجة قبل الإطلاق؛ إعادة تقييم خلال 6 أشهر
200-153	حرج	عدم المتابعة حتى يصبح الخطر المتبقي $\geq$ متوسط؛ التصعيد لمسؤول حماية البيانات

شرط استشارة الجهة التنظيمية: إذا بقي الخطر المتبقي مرتفعاً/حرجاً بعد المعالجة، يجب استشارة الجهة الإشرافية — مكتب البيانات الإماراتي (الإمارات) أو سدايا/المكتب الوطني لإدارة البيانات (السعودية) — قبل المعالجة.

هـ. تدابير المعالجة

#	الضوابط	تمت معالجته؟	الاحتمالية المتبقية	الأثر المتبقي
E1	التشفير (AES-256 أثناء التخزين، TLS 1.2 + أثناء النقل)	☐	5/ __	5/ __
E2	ضوابط الوصول القائمة على الأدوار (RBAC)	☐	5/ __	5/ __
E3	الحذف التلقائي / إخفاء الهوية	☐	5/ __	5/ __
E4	تصنيف الغرض + إنفاذ الأساس القانوني	☐	5/ __	5/ __
E5	التقسيم الجغرافي + الشروط النموذجية/الكفاية للنقل	☐	5/ __	5/ __
E6	وجود عنصر بشري في القرارات الآلية	☐	5/ __	5/ __
E7	اتفاقية معالجة بيانات مع الموّرد + استبيان أمني + بند الانتهاك	☐	5/ __	5/ __
E8	سير عمل طلبات أصحاب البيانات بمهلة 30 يوماً + محرك المحو	☐	5/ __	5/ __

و. الخطر المتبقي والاعتماد

الحقل	القيمة
درجة الخطر المتبقي (بعد المعالجة)	[residual_risk_score]
نطاق الخطر المتبقي	☐ منخفض ☐ متوسط ☐ مرتفع ☐ حرج
مراجعة مسؤول حماية البيانات	[dpo_review_date] — [dpo_reviewer]

الحقل	القيمة
اعتماد جهة التحكم	[sign_off_date] — [controller_sign_off]
تاريخ المراجعة التالي	[review_due_date]